Financial (GLBA/SOX) DLP Pack — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 5

Boundaries (so scope is clear) . . . 5

1. Solution Overview — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 5

What this solution is . . . 5

Why this matters . . . 6

How it works . . . 6

The five DLP locations (and what each controls for financial data) . . . 7

The simulate→enforce journey (the core discipline) . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 9

2. Requirements — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 9

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP and advanced classifiers . . . 9

2.2 DLP-specific least-privilege roles (with author/triage separation for finance) . . . 10

2.3 Devices onboarded to Purview for Endpoint DLP (finance/treasury endpoints) . . . 10

2.4 A financial/NPI classification intent and a sensitive-information-type inventory . . . 10

2.5 Source data for Exact Data Match and statement fingerprinting (only if used) . . . 11

2.6 A finance pilot ring, simulation dwell time, and change control (DLP-specific) . . . 11

2.7 A financial DLP alert triage owner and destination . . . 12

Global Requirements — Microsoft Purview Solutions 13

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13

2. Purview roles (least-privilege) and portal access . . . 13

3. Security & Compliance PowerShell + Graph toolchain . . . 14

4. Data sources & scope in scope . . . 14

5. Compliance, records, privacy & legal stakeholders . . . 14

6. A pilot scope and change control . . . 15

3. Implementation Guide — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 15

Phase 0 — Connect and baseline (Assess) . . . 15

Phase 1 — Design the financial classification layer (SITs, EDM, fingerprints, classifiers) . . . 16

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact) . . . 17
Phase 3 — Measure and tune (drive false positives down) . . . 18
Phase 4 — Enforce in the finance pilot ring (Pilot) . . . 18
Phase 5 — Expand and harden (Enforce → Operate) . . . 19
Order-of-operations summary . . . 19
5. Testing & Validation — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 20
Test A — Detection & enforcement (financial/NPI leaks are blocked) . . . 20
Test B — False-positive rate (adoption gate) . . . 21
Test C — Incident / alert handling (the control is operable) . . . 22
Simulation-first & rollback validation . . . 23
Evidence to capture (for the GLBA/SOX control record) . . . 23
6. Troubleshooting — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 24
Policy / detection . . . 24
Endpoint DLP (finance/treasury laptops) . . . 25
False positives (the adoption killer for finance) . . . 25
Alerts / incident handling . . . 26
Connectivity / tooling . . . 26
7. Best Practices — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 27
Simulate before you enforce — always . . . 27
Tune for a low false-positive rate (adoption depends on it) . . . 28
Right-size the user experience for finance . . . 28
Endpoint DLP specifics (finance/treasury laptops) . . . 28
Classification hygiene . . . 28
GLBA/SOX operations & governance . . . 29
Stay inside the boundary . . . 29
8. Deliverables Summary — Financial (GLBA/SOX) DLP Pack (Microsoft Purview) 29
Documentation . . . 30
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 30
Definition of done . . . 31
Appendix A — PowerShell Scripts 33

Executive Summary — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

The problem

Financial institutions and public companies hold data that regulation says must not leak: **customer nonpublic personal information (NPI)** protected under the **Gramm-Leach-Bliley Act (GLBA)** — account and card numbers, bank routing/account numbers, Social Security / taxpayer numbers — and **financial-reporting data and material non-public information** whose integrity underpins **Sarbanes-Oxley (SOX)** controls. Both walk out through everyday channels: an emailed account export, a general-ledger extract shared "anyone with the link," card numbers pasted into Teams, or a draft statement copied to a USB stick. Without a working data-loss control those leaks are invisible until they become an incident — and the common failed attempt, switching controls straight to "block," floods the help desk with false positives (GL codes, invoice IDs) and gets turned off within a week.

The solution

Stand up **Microsoft Purview Data Loss Prevention (DLP)** tuned for financial and customer data across all five locations — **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. Detection is driven by **financial sensitive information types** (built-in card/routing/account/SSN/ITIN types, the **GLBA / U.S. Financial Data** templates, plus **Exact Data Match**, **document fingerprinting** of statement templates, and **trainable classifiers**), and the defining discipline is that **every policy is built and proven in SIMULATION first** — Microsoft's built-in test mode that shows what *would* be blocked with zero user impact — then tuned for a **low false-positive rate**, then enforced to a **finance pilot ring**, then expanded. The result: financial and NPI leaks are blocked without blocking month-end close.

What it delivers

- A mapped **financial classification layer** — the right detector for each in-scope NPI/financial category, reusing built-in types and GLBA templates and adding custom SITs / EDM / fingerprints only for real gaps (internal account numbers, GL codes, statement templates).
- **DLP policies across email, cloud, Teams, endpoint, and a dedicated SOX financial-records policy**, each proven in simulation, tuned, and enforced through policy tips, justification/override, or block/encrypt.
- A **measured false-positive rate** kept at/under an agreed threshold across a reporting cycle — the difference between a control finance trusts and one they ignore.
- A **financial incident/alert triage workflow** with controlled access to NPI evidence, an Activity Explorer trail, and optional SIEM forwarding.
- **Five PowerShell tools** (posture assessment, policy config helper, validation runner, match/false-positive report, scope/health helper) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

• **Financial/NPI leaks blocked** across the channels data actually walks out through — email, cloud sharing, and USB/print on finance endpoints.

• **Minimal disruption** — simulation-first plus tuning means the control catches leaks without a wave of false positives on GL/reference numbers, and any policy reverts to simulation instantly if needed.

• **Defensible and auditable** — matches raise alerts triaged to disposition, with evidence retained for the GLBA safeguards / SOX control record.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and tooled to run in-house.

Boundaries (so scope is clear)

DLP is licensing-/plan-dependent — **Endpoint DLP, EDM, fingerprinting, and trainable classifiers require E5 / E5 Compliance and onboarded devices** (verify your tenant), and template names/portal paths evolve. This solution provides the **technical configuration and the evidence**; *which* data is NPI under GLBA, *which* records are SOX-scoped, *which* classifiers legally apply, the **enforced action per category**, any **retention obligation**, and the **acceptable false-positive threshold** are **compliance, records, privacy, and legal determinations**, captured alongside the delivered evidence.

1. Solution Overview — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

What this solution is

Financial institutions and public companies hold two categories of data that must not leak: **customer nonpublic personal information (NPI)** protected under the **Gramm-Leach-Bliley Act (GLBA)** — account numbers, bank routing/account numbers, card numbers, Social Security / taxpayer numbers, and the personally identifiable financial information tied to them — and **financial-reporting and material non-public information (MNPI)** whose integrity and confidentiality underpin **Sarbanes-Oxley (SOX)** controls over financial reporting. Both walk out through the same everyday channels: an email with a customer account export attached, a general-ledger extract shared "anyone with the link" from SharePoint or OneDrive, card or routing numbers pasted into a Teams chat, or a draft earnings file copied to a USB stick or printed.

Microsoft Purview Data Loss Prevention (DLP) detects and controls that movement by matching the *content* being shared against **sensitive information types (SITs)** and **classifiers**, then applying a policy action — audit only, warn with a **policy tip**, allow with a business **justification**, or **block** — across **Exchange email, SharePoint, OneDrive, Teams, and Endpoint (managed devices)**. This pack is a repeatable, evidence-driven way to stand up **GLBA/SOX-aligned DLP for financial and NPI data** using only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party DLP tooling. Its defining discipline is that **every policy is built and**

proven in SIMULATION mode first (Microsoft's built-in test mode that evaluates policy against real traffic and shows what *would* have matched, with zero user impact), tuned for a low false-positive rate, then enforced to a pilot ring, then expanded.

> ***Scope boundary.*** *This solution delivers the **technical method and evidence** for DLP configuration. *Which* data is NPI under GLBA, *which* records fall in SOX scope, *which* classifiers legally apply, what the **enforced action** must be for a given category, and any **records-retention** obligation are **compliance, privacy, records, and legal determinations** — deferred to those functions. The solution helps you configure and prove the control; it does not make the regulatory determination.*

Why this matters

- **GLBA's Safeguards Rule** obligates financial institutions to protect customer NPI. DLP that detects

and controls NPI movement across mail, cloud, and endpoints is a direct, demonstrable safeguard — and the simulation evidence is exactly the kind of artifact an examiner or auditor expects.

- **SOX** cares about the integrity and confidentiality of financial-reporting data and MNPI. DLP reduces

the risk of pre-release financial data or general-ledger extracts leaving through uncontrolled channels — a control that supports (does not replace) the broader ICFR program.

- DLP switched straight to **enforce** without simulation is the classic failure: it blocks legitimate

finance workflows (statements, reconciliations, vendor payments), floods the help desk, and gets disabled within a week. Simulation-first is the difference between a control that survives an audit and one that was turned off before it.

- Financial SITs are **prone to false positives** — a built-in *Credit Card Number* or *ABA Routing

Number* detector fires on internal reference numbers, GL codes, and invoice IDs. Tuning (confidence levels, instance counts, supporting keywords, Exact Data Match) is what makes the control trusted.

How it works

1. **Sensitive information types (SITs) and classifiers** define *what* to look for. Purview ships

built-in **financial SITs** — *Credit Card Number*, *ABA Routing Number*, *U.S. Bank Account Number*, *International Banking Account Number (IBAN)*, *SWIFT Code*, *U.S. Social Security Number (SSN)*, and *U.S. Individual Taxpayer Identification Number (ITIN)* among them — and ships **DLP policy templates** for **U.S. Gramm-Leach-Bliley Act (GLBA)** and **U.S. Financial Data** (verify the exact template name and SIT membership in your tenant — templates evolve). Where built-ins don't fit (internal account numbers, GL/cost-center codes, statement templates) you add **custom SITs** (regex + keyword + confidence), **Exact Data Match (EDM)** SITs (matched against a hashed upload of your real account data for near-zero false positives), **document fingerprinting** of financial-statement templates, and **trainable classifiers** (verify availability/plan).

1. **DLP policies** bind those SITs to **locations** (Exchange, SharePoint, OneDrive, Teams, and

Devices/Endpoint) with **conditions** (which SIT, how many instances, what confidence), **actions** (audit / notify / restrict / block, restrict USB/print/cloud-app upload on endpoint), and **user experience** (policy tips, allow-with-justification, allow-override).

1. **Simulation mode** runs each policy against live traffic and records what *would* have matched — with

or without policy tips shown — so you see true hit volume and false positives **before** any enforcement. Every policy in this pack starts here.

1. **Tuning** reduces false positives using confidence levels, instance thresholds, supporting keyword

evidence, EDM, and exceptions — measured against the simulation results.

1. **Enforcement** turns the tuned policy on (tips/override/block) in a limited **finance pilot ring**,

then expands.

1. **Incident/alert handling** — DLP rule matches raise **alerts** in the Purview portal and events flow

to **Activity Explorer**; this solution wires the triage, severity, and response workflow so financial matches are actually acted on.

The five DLP locations (and what each controls for financial data)

• **Exchange (email):** outbound mail with account exports, statements, or card/routing numbers; block or

encrypt on match.

• **SharePoint & OneDrive:** GL extracts, reconciliations, and customer records at rest and when shared;

block external sharing on match.

• **Teams chat & channel messages:** account/card numbers or MNPI pasted into finance channels.

• **Endpoint (Devices):** activities on **onboarded** Windows/macOS devices — copy financial files to USB,

print, upload to unallowed cloud apps/browsers, copy to clipboard/paste to browser. **Requires onboarding and the right licensing.**

• **Cloud apps / on-premises / Fabric / Power BI:** additional locations that may be available depending

on licensing — **verify availability in your tenant.**

The simulate→enforce journey (the core discipline)

> *Map financial/NPI SITs and classifiers → build each DLP policy in **SIMULATION** (no user impact) → measure hit volume and false positives in **Activity Explorer / DLP alerts** → **tune** (confidence, instance count, keywords, EDM, exceptions) → re-simulate until false positives are acceptable → enable with **policy tips + allow-override/justification** in a **finance pilot ring** → validate → expand to **enforce (block)** per compliance's action determination → operate (triage alerts, review overrides, re-tune).*

What you can control

• Which financial/NPI SITs/classifiers are in scope, and at what **confidence** and **instance count**

they trigger.

• Which **locations** each policy covers and which users/sites/groups (e.g. Finance, Treasury) are

included or excluded.

- The **action** per data category (audit → tip → justify → block) — set per compliance's determination.
- Whether users get **policy tips**, can **override** with justification, and what the override says.
- The **finance pilot ring** enforced first, and the simulation dwell time before enforcement.

Limitations (be honest with buyers)

- **Endpoint DLP and several advanced classifiers require onboarded devices and E5 / the E5 Compliance

add-on** (verify your plan). A Devices-location policy is inert until onboarding is complete.

- **Some features are in preview** and portal paths / template names **evolve** — this pack flags "verify

your licensing/tenant" rather than asserting availability or an exact template name that may differ in your tenant.

- DLP inspects **content it can classify**; strongly encrypted or unrecognized formats, or content below

the confidence/instance threshold, won't match. DLP is one control among several (labels, encryption, insider risk, access controls), not a guarantee of GLBA/SOX compliance on its own.

- **EDM, document fingerprinting, and trainable classifiers require setup and, for EDM, an ongoing data

refresh**; they drive false positives down but are not zero-effort.

- **Which data is NPI/SOX-scoped, the enforced action per category, and any retention obligation are

compliance/legal determinations**, not technical defaults — this pack configures and proves the control; the determination is deferred.

Naming convention (used in every doc and script)

Every artifact uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
Custom SIT (internal account no.)	`Account Number – Custom SIT – Financial`
Custom SIT (GL / cost-center code)	`GL Account Code – Custom SIT – Financial`
EDM schema / SIT (customer records)	`Customer NPI – EDM – Financial`
Document fingerprint (statements)	`Financial Statement – Fingerprint – SOX`
Email DLP policy (simulation)	`DLP – Email NPI – Simulation`
Cloud DLP policy (simulation)	`DLP – SPO+OneDrive+Teams NPI – Simulation`
Endpoint DLP policy (simulation)	`DLP – Endpoint NPI – Simulation`
SOX financial-records policy (sim.)	`DLP – SOX Financial Records – Simulation`
Enforced pilot policy	`DLP – All Locations NPI – Enforce Pilot`
Finance pilot user ring	`DLP Pilot Ring – Finance Stage1`

Artifact	Name
Policy-tip / override text	`DLP Notice – GLBA NPI – AllPolicies`
Incident/alert workflow	`DLP Alerts – Financial – Operations`

The standard deployment model

> ***Assess*** *current financial-data exposure and classification intent →* ***Design*** *SITs/classifiers, policies, and user experience →* ***Configure*** *SITs and policies* ***in simulation*** *→* ***Pilot*** *(simulate → tune → enforce to the finance ring) →* ***Validate*** *against pass/fail gates (leaks blocked, false-positive rate low, incidents handled) →* ***Expand*** *to full enforcement and ongoing operations. Every high-impact change is piloted in simulation first, with a documented rollback.*

2. Requirements — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

These are the **solution-specific** prerequisites for implementing GLBA/SOX-aligned DLP for financial and NPI data across endpoint, cloud, and email. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the DLP features you will use — especially Endpoint DLP and advanced classifiers

• **Description:** DLP for **Exchange/SharePoint/OneDrive/Teams** with **built-in financial SITs** is broadly available, but **Endpoint DLP**, **Exact Data Match (EDM)**, **document fingerprinting**, and **trainable classifiers** are **plan-gated** — typically **Microsoft 365 E5** or the **E5 Compliance** add-on (some capabilities are in **preview**). This extends GR-#1 with the DLP-specific plan detail.

• **Why required:** A DLP policy scoped to a location or using a classifier your plan doesn't include will not function. Endpoint DLP for finance laptops in particular is an E5/E5-Compliance capability.

• **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the **Purview portal** → **Data Loss Prevention** confirm the **Endpoint DLP** / **Devices** location and the classifier types (EDM, fingerprinting, trainable) you intend to use are visible. **Flag "verify your licensing/tenant"** — availability evolves.

• **How to implement if missing:** Acquire/assign the required licensing (E5 or E5 Compliance) before building endpoint or advanced-classifier policies; scope the initial rollout to features your plan covers (built-in financial SITs on mail/cloud work at lower tiers).

2.2 DLP-specific least-privilege roles (with author/triage separation for finance)

• **Description:** The **DLP role groups** in the Purview portal — **Compliance Administrator** or

Compliance Data Administrator to create/manage DLP policies, **DLP Compliance Management** for policy management, **View-Only DLP Compliance Management** for read-only review, and the **Data Loss Prevention** role for alert/incident handling. Global Administrator only where genuinely required. Because financial matches are sensitive, **separate policy authors from alert triagers** where possible. Extends GR-#2.

• **Why required:** Purview enforces fine-grained role groups; DLP configuration and alert triage require

the matching role, and least privilege plus author/triage separation keeps the blast radius small and supports segregation-of-duties expectations relevant to SOX.

• **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (Microsoft Purview

roles) — confirm your account's role-group membership includes the DLP roles you need.

• **How to implement if missing:** Assign the least-privilege DLP role group under change control;

document who authors policies versus who triages financial DLP alerts.

2.3 Devices onboarded to Purview for Endpoint DLP (finance/treasury endpoints)

• **Description:** Endpoint DLP monitors activities on **onboarded Windows 10/11 and macOS devices**.

Onboarding is done in **Purview portal** → **Settings** → **Device onboarding** (or via Intune / a script / Group Policy) and is **shared with Microsoft Defender for Endpoint onboarding** — devices already onboarded to Defender for Endpoint are onboarded for Endpoint DLP. Prioritize **finance, treasury, and accounting endpoints** where financial files are handled.

• **Why required:** A DLP policy scoped to the **Devices** location does nothing on a device that is not

onboarded and reporting. Onboarding is the hard prerequisite for any endpoint control.

• **How to verify: Purview portal** → **Settings** → **Device onboarding** → **Devices** shows onboarded devices;

confirm target finance devices appear and are reporting.

• **How to implement if missing:** Onboard devices via the Purview device-onboarding package, Intune, or

Group Policy; confirm the minimum OS build and any required Antimalware/AV state per Microsoft docs before scoping endpoint policies.

2.4 A financial/NPI classification intent and a sensitive-information-type inventory

• **Description:** A documented view of the **financial and NPI data you are protecting** (customer

account numbers, bank routing/account numbers, card data, SSN/ITIN, GL extracts, financial statements, MNPI) mapped to the **SITs/classifiers** that detect it — built-in financial SITs and the **GLBA / U.S. Financial Data** DLP templates where they fit, **custom SITs / EDM / fingerprinting / trainable classifiers** where they don't. Extends GR-#4.

- **Why required:** DLP policies key off SITs; without knowing which financial data matters and which SIT detects it (at what confidence and instance count), policies are guesswork and generate false positives on GL codes, invoice IDs, and reference numbers.
- **How to verify: Purview portal** → **Data classification** → **Classifiers** → **Sensitive info types** lists built-in and custom SITs; confirm the financial ones you need exist (or are planned). Confirm the data categories with the data owners / controller's office.
- **How to implement if missing:** Build the SIT inventory (this pack's Discovery script assesses built-in financial-SIT coverage); plan custom SITs / EDM / fingerprinting for internal account numbers, GL codes, and statement templates not covered by built-ins.

2.5 Source data for Exact Data Match and statement fingerprinting (only if used)

- **Description:** For **EDM** SITs, a **sensitive data table** (e.g. an export of customer account records) and a workstation with the **EDM Upload Agent** to hash and upload it — raw data never leaves your control; only salted hashes are uploaded. For **document fingerprinting**, the **financial-statement templates** (e.g. the standard reporting workbook/letter formats) to fingerprint.
- **Why required:** EDM matches against *your actual account data*, driving false positives toward zero; fingerprinting matches your *actual statement templates*. Both require the source material and, for EDM, a **refresh cadence** as the data changes.
- **How to verify:** Confirm the source table, the EDM schema, the upload-agent host, and a scheduled refresh. **Purview portal** → **Data classification** → **Exact data matches** shows configured EDM schemas.
- **How to implement if missing:** Define the EDM schema and refresh process (deferred to the data owner for *which* fields are in scope); provide statement templates for fingerprinting. If EDM/fingerprinting is not in your plan or not needed, use custom SITs with confidence/keyword tuning instead.

2.6 A finance pilot ring, simulation dwell time, and change control (DLP-specific)

- **Description:** A named **finance pilot user/device ring** (`DLP Pilot Ring – Finance Stage1`), an agreed **simulation dwell time** (long enough to capture representative finance traffic — month-end and reporting cycles matter here), and the **change-control window** for moving simulation → enforce. Extends GR-#6.
- **Why required:** Financial DLP is high-impact; enforcing without a simulation baseline and a limited

ring is how DLP breaks month-end close and payments. The house model mandates **simulation first**, then a ring, then expand.

• **How to verify:** Confirm the pilot ring membership, that **simulation mode** is selected on each new policy, and the approval path to enforce.

• **How to implement if missing:** Define the ring and dwell time (span at least one reporting cycle) and agree change control before enabling any enforcement action.

2.7 A financial DLP alert triage owner and destination

• **Description:** A named owner (or queue) for **financial DLP alerts** raised in **Purview portal → Data loss prevention → Alerts (`DLP Alerts – Financial – Operations`), plus where events are reviewed (**Activity Explorer**) and, optionally, forwarded (SIEM/Microsoft Sentinel via the Office 365 Management Activity API / Defender connectors). Severity and response actions defined; because matches may expose customer NPI, define** who may view match evidence**.

• **Why required:** A financial DLP match with no one to triage it is not a control. Alerts and Activity Explorer are where matches surface; someone must own triage, severity, and response — with appropriate handling of the NPI in the evidence.

• **How to verify:** Confirm the triage owner/queue, the alert-severity scheme, who may view NPI evidence, and any SIEM forwarding is configured.

• **How to implement if missing:** Assign the owner, define severity/response and evidence-access, and (optionally) wire SIEM forwarding before enforcement generates real alerts.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	DLP/Endpoint + advanced-classifier licensing (E5 / E5 Compliance; verify)	Endpoint, EDM, fingerprinting, trainable available
2.2	DLP least-privilege roles + author/triage separation	SoD-aware author + triage roles assigned
2.3	Finance devices onboarded to Purview	Endpoint location functional on finance endpoints
2.4	Financial/NPI classification intent + SIT inventory	Policies key off correct financial SITs
2.5	EDM source data / statement fingerprints (if used)	Near-zero-FP matching where needed

#	Requirement	Gate
2.6	Finance pilot ring + simulation dwell + change control	Simulate-first enforced across a reporting cycle
2.7	Financial alert/incident triage owner + evidence access	NPI matches are acted on and evidence controlled

> ***Deferred to compliance/records/privacy/legal:*** *which data is NPI under GLBA, which records fall in SOX scope, which classifiers legally apply, the enforced action per category, retention obligations, and any regulatory applicability. This solution provides the technical configuration and evidence, not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

This is the exact, ordered procedure to implement GLBA/SOX-aligned DLP for **financial and NPI data** across **email, cloud, Teams, and endpoint** — every policy built in **SIMULATION** first, tuned, then enforced in a finance ring, then expanded. Portal paths, cmdlets, SIT names, and template names are from Microsoft's public documentation; **licensing-/plan-dependent features, evolving portal paths, and template names are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through **Security & Compliance PowerShell** (`Connect-IPPSSession`) and **Microsoft Graph**. They are **read-only or** `-WhatIf` **by default**; writes require an explicit* `-Commit` *switch and never leave a policy in enforce. No credentials are stored in code.*
>
> ***Determinations deferred.*** **Which* data is NPI under GLBA, *which* records fall in SOX scope, *which* classifiers legally apply, the *enforced action* per category, and any *retention* obligation are **compliance/records/privacy/legal** decisions. This guide configures and proves the control; capture those decisions before Phase 4.*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','InformationProtectionPolicy.Read' -NoWelcome
```

1. **Run the posture assessment** (delivered script #1, read-only):

```
.\DLPFIN-Discovery.ps1 -CsvPath .\DLPFIN-Posture.csv
```

It reports existing DLP policies and their mode, built-in **financial-SIT** coverage vs custom SITs, any EDM schemas, and licensing/endpoint readiness signals.

1. **Confirm licensing and endpoint readiness** (Req 2.1, 2.3): confirm E5/E5-Compliance where endpoint,

EDM, fingerprinting, or trainable classifiers are needed, and that finance devices are **onboarded** (the health check in script #5 reports the endpoint signal).

Pass/fail gate: you have a written baseline (existing policies + modes), a financial-SIT coverage map, and confirmed licensing + endpoint onboarding for the locations you will target. **Rollback:** none (read-only).

Phase 1 — Design the financial classification layer (SITs, EDM, fingerprints, classifiers)

Decide, per in-scope financial/NPI category, which detector applies. Do **not** invent SITs — use built-in where they fit; build custom/EDM/fingerprint/trainable only for gaps.

1. **Map built-in financial SITs first.** In **Purview portal → Data classification → Classifiers →

Sensitive info types**, confirm the built-in SITs for your categories — e.g. *Credit Card Number*, *ABA Routing Number*, *U.S. Bank Account Number*, *International Banking Account Number (IBAN)*, *SWIFT Code*, *U.S. Social Security Number (SSN)*, *U.S. Individual Taxpayer Identification Number (ITIN)*. Note each SIT's** confidence levels **and default** instance count**. Review the built-in** U.S. Gramm-Leach-Bliley Act (GLBA) **and** U.S. Financial Data **DLP** templates** to see the SIT bundles Microsoft groups for financial data (*verify the exact template names/membership in your tenant — templates evolve*).

1. **Author custom SITs for internal financial identifiers.** For categories with no built-in match:

• `Account Number – Custom SIT – Financial` — internal customer/account number format (regex primary

pattern + supporting keywords like *account*, *acct #* + confidence + character proximity).

• `GL Account Code – Custom SIT – Financial` — general-ledger / cost-center code format.

Portal: **Classifiers** → **Sensitive info types** → **Create sensitive info type**. Test each against sample text in the wizard's **Test** step. *Note: over-broad numeric patterns are the top false-positive source — require keywords/proximity.*

1. **Configure EDM for customer records where near-zero false positives are required** (Req 2.5). Define

the schema `Customer NPI – EDM – Financial`, hash-and-upload the source table with the **EDM Upload Agent**, and set a **refresh cadence**. Portal: **Data classification** → **Exact data matches**. *Which fields are in scope is the data owner's determination.*

1. **Fingerprint financial-statement templates for SOX** (Req 2.5, plan-gated). Create

`Financial Statement – Fingerprint – SOX` from your standard statement/reporting template(s) via **Document fingerprinting** so drafts based on those templates are detectable. Verify document fingerprinting is available in your plan.

1. **Add trainable classifiers where a category is conceptual, not pattern-based** (e.g. financial

statements, MNPI-style content) — use a built-in trainable classifier or train a custom one on sample content. **Verify availability against your plan** before relying on it.

Pass/fail gate: every in-scope financial/NPI category maps to a named, tested SIT/EDM/fingerprint/ classifier at a chosen confidence and instance count. **Rollback:** delete unused custom SITs/EDM schemas/fingerprints (they have no effect until referenced by a policy).

Phase 2 — Build the DLP policies in SIMULATION (Configure — no user impact)

Create **one policy per location group plus a SOX financial-records policy**, each in **simulation mode**. Simulation evaluates against real traffic and records what *would* match, with **no** enforcement and (optionally) with policy tips shown.

1. **Email NPI DLP policy —** `DLP – Email NPI – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** → the **GLBA / U.S. Financial Data** template or custom → **Locations: Exchange email only** → rule: condition *Content contains* the financial/NPI SITs from Phase 1 at the chosen confidence/instance count → action *Restrict access or encrypt* (kept inert by simulation) → **Policy mode: Run the policy in simulation mode** (optionally *with policy tips*). Finish.

1. **Cloud NPI DLP policy —** `DLP – SPO+OneDrive+Teams NPI – Simulation`**.**

Same flow → **Locations: SharePoint sites, OneDrive accounts, Teams chat and channel messages** → conditions as above → action *Restrict access* (block external sharing on match) → **simulation mode**.

1. **Endpoint NPI DLP policy —** `DLP – Endpoint NPI – Simulation` (requires onboarded devices +

licensing). Same flow → **Locations: Devices** → conditions as above → **endpoint activities to audit/restrict**: *copy to USB/removable media*, *copy to network share*, *print*, *upload to unallowed cloud apps/browser*, *copy to clipboard*, *paste to browser* → **simulation mode**. Confirm the Devices location is selectable (if not, revisit licensing/onboarding — Req 2.1/2.3).

1. **SOX financial-records DLP policy —** `DLP – SOX Financial Records – Simulation`**.**

Same flow → **Locations: Exchange + SharePoint + OneDrive + Teams** → conditions: *Content contains* the `GL Account Code – Custom SIT – Financial`, the `Financial Statement – Fingerprint – SOX`, and/or the financial-statements trainable classifier → action *Restrict access* → **simulation mode**. This policy targets financial-reporting content/MNPI rather than customer NPI.

1. **Set the user experience** consistently: define `DLP Notice – GLBA NPI – AllPolicies` policy-tip text

(business language: *this content appears to contain protected financial/customer information*) and enable **allow override with justification** where compliance permits — tips/overrides only *appear* once a policy is enforced; in simulation they are captured, not shown unless "simulation with policy tips" is selected.

1. **Verify with the config helper** (delivered script #2, `-WhatIf` by default):

```
.\DLPFIN-Config.ps1 -PolicyName 'DLP - Email NPI - Simulation' `
    -Locations Exchange -SensitiveTypes 'Credit Card Number','ABA Routing Number','U.S. Bank Account N
```

```
-MinCount 10 -Confidence High -WhatIf
```

Run with `-Commit` only to apply an intended change; the script never leaves a policy in enforce mode.

Pass/fail gate: all four policies exist and are confirmed in **simulation** (script #1/#2 report `Mode = TestWithNotifications / TestWithoutNotifications`), scoped to the correct locations and financial SITs. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is clean.

Phase 3 — Measure and tune (drive false positives down)

Let each policy run in simulation for the agreed **dwell time** (Req 2.6 — span at least one reporting/ month-end cycle) to capture representative finance traffic.

1. **Review what matched. Purview portal** → **Data loss prevention** → **Alerts** (simulation alerts) and

Data classification → **Activity explorer** (filter to DLP activities) show every simulated match with the file/message, the SIT, and the confidence. Export with the reporting script:

```
.\DLPFIN-Report.ps1 -Days 30 -CsvPath .\DLPFIN-Matches.csv
```

1. **Classify each match** as true positive or **false positive** and identify the false-positive drivers

(e.g. *ABA Routing Number* firing on internal reference numbers, *Credit Card* firing on GL codes, an over-broad `Account Number` custom SIT firing on invoice IDs).

1. **Tune** to reduce false positives without losing true positives:

• Raise the **confidence level** (e.g. medium → high) so only high-confidence matches count.

• Raise the **instance count** (e.g. require ≥10 account/card numbers, not 1) for bulk-leak focus.

• Add **supporting keywords / proximity** to custom SITs so financial context is required.

• Introduce **EDM** for customer NPI where pattern SITs over-match.

• Add **exceptions** (e.g. exclude the payments-processor mailbox or the reconciliation site) where

justified and documented.

1. **Re-simulate** after each tuning change and re-measure. Repeat until the false-positive rate meets the

validation gate (see Testing).

Pass/fail gate: measured false-positive rate is at/under the agreed threshold on the simulation sample, with true positives still detected. **Rollback:** revert the last tuning change (script #2 `-WhatIf` shows the diff before `-Commit`).

Phase 4 — Enforce in the finance pilot ring (Pilot)

Capture the compliance/legal determinations (enforced action per category) before this phase.

1. **Scope to the finance ring.** Add `DLP Pilot Ring – Finance Stage1` (Finance/Treasury/Accounting

users) and their pilot devices as the **included** scope on each policy (all other users/devices excluded for now). Use the scope helper:

```
.\DLPFIN-Scope.ps1 -PolicyName 'DLP - Email NPI - Simulation' `
    -PilotRingGroup 'DLPFinancePilot@contoso.com' -Location Exchange -Commit
```

1. **Move the ring to enforcement.** Change **Policy mode** from *simulation* to **Turn it on / Enforce**.

Start with **policy tips + allow-override (justification)** rather than hard block, so the finance pilot can report false negatives/positives while retaining a business escape hatch for legitimate workflows (statements, vendor payments).

1. **Confirm enforcement is live** for the ring only (script #1/#3 report mode `Enable` and the scoped identities). Confirm ring users now see the `DLP Notice – GLBA NPI – AllPolicies` tip on a test match.

1. **Handle incidents.** Wire `DLP Alerts – Financial – Operations`: assign the alert owner/queue

(Req 2.7), set severities, control who may view NPI evidence, and (optionally) forward to SIEM/Sentinel. Triage a real simulated/pilot alert end-to-end to prove the workflow.

Pass/fail gate: the finance ring is enforced (tips shown, overrides captured), matches raise alerts, and the triage workflow produces a dispositioned incident. No enforcement outside the ring. **Rollback:** set the policy back to **simulation mode** (single setting) — instantly removes enforcement with no data change.

Phase 5 — Expand and harden (Enforce → Operate)

1. **Expand scope** from the finance ring to the full intended population once the pilot gate passes, keeping documented exclusions.

1. **Escalate the action** per compliance's determination — e.g. move customer-NPI email from *tip + override* to **block/encrypt** where required — one category/location at a time, re-validating after each.

1. **Operationalize:** schedule the reporting script for a recurring false-positive/alert review, review **user overrides** (are finance users justifying legitimately or bypassing?), refresh **EDM** data on cadence, re-fingerprint statement templates when they change, and re-tune as data and behavior drift.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail evidence for the GLBA safeguards / SOX control record.

Pass/fail gate: enforcement live across the intended scope with the compliance-mandated action per category; false-positive rate steady/low; alerts triaged on cadence; overrides reviewed; evidence retained. **Rollback:** any policy can be returned to **simulation** at any time as an immediate, non-destructive safety switch; individual policies can be disabled without affecting others.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline, confirm licensing/onboarding	Posture CSV	Baseline + readiness confirmed	n/a (read-only)

Phase	Do	Artifact(s)	Gate	Rollback
1 Design	Map/build financial SITs, EDM, fingerprints, classifiers	Custom SITs / EDM / fingerprint	Every category → tested detector	Delete unused SIT/EDM/fingerprint
2 Configure	Build 4 policies in **simulation**	Email/Cloud/Endpoint NPI + SOX sim policies	All in simulation, correct scope	Delete sim policy
3 Tune	Measure + reduce false positives	Matches CSV	FP rate ≤ threshold	Revert tuning change
4 Pilot	Enforce to finance ring, wire alerts	Finance ring, alert triage	Ring enforced, incident dispositioned	Back to simulation
5 Expand	Broaden scope, escalate to block, operate	Enforced policies	Full-scope enforce, low FP, alerts triaged	Simulation / disable

5. Testing & Validation — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

Validate the financial DLP implementation against explicit **pass/fail gates**. The three headline gates are: **(A) financial/NPI leaks are blocked**, **(B) the false-positive rate is low**, and **(C) incidents are handled**. Run every test with **non-real, clearly-fake sample data** — e.g. the Microsoft-documented test credit-card number `4111 1111 1111 1111`, a fake routing number, and a synthetic account number — **never real customer NPI or actual financial statements**, and record the evidence.

> *All tests assume the policies from the Implementation Guide, first proven in **simulation** and then enforced to the **finance pilot ring**. Endpoint tests require an **onboarded** device (Req 2.3).*

Test A — Detection & enforcement (financial/NPI leaks are blocked)

#	Test	Steps	Pass condition
A1	Email NPI blocked	From a finance-ring user, send an email to an **external** recipient containing enough fake account/card/routing numbers to meet the threshold.	Message is blocked/encrypted per the enforced action; sender sees the policy tip; a DLP alert is raised.

#	Test	Steps	Pass condition
A2	Cloud external share blocked	As a ring user, upload a file with fake NPI (e.g. a fake account-number list) and attempt to share it **externally** from SharePoint/OneDrive.	External sharing is blocked/restricted on match; event appears in Activity Explorer.
A3	Teams NPI message match	Paste fake card/account numbers into a finance Teams chat/channel covered by the policy.	Message is blocked or tipped per the enforced action; event logged.
A4	Endpoint — USB copy	On an onboarded ring device, copy a file containing fake NPI to **removable media**.	Activity is audited/blocked per policy; endpoint DLP event appears in Activity Explorer.
A5	Endpoint — print / cloud upload	On the ring device, attempt to **print** the fake-NPI file and **upload** it to an unallowed cloud app/browser.	Each activity is audited/restricted per policy; events logged.
A6	SOX financial-record match	Share a document based on the fingerprinted `Financial Statement – Fingerprint – SOX` template (or containing fake GL codes) externally.	The SOX financial-records policy matches per its enforced action; event logged.
A7	Below-threshold negative	Send content with **fewer** SIT instances than the threshold (or lower confidence).	Correctly **not** matched — confirms the threshold/confidence tuning holds.

Gate A (pass): A1–A6 each produce the enforced action and a logged event; A7 correctly does not match.

Test B — False-positive rate (adoption gate)

#	Test	Steps	Pass condition
B1	Simulation FP baseline	Over the agreed dwell time (spanning a month-end/reporting cycle), export simulation matches (`DLPFIN-Report.ps1 -Days <n>`) and classify each as TP/FP.	**False-positive rate** ≤ **the agreed threshold** (define with compliance; a common target is ≤10% of matches, or an absolute FP count the triage team can absorb).
B2	Legitimate finance-traffic negative	Run representative legitimate finance content (invoices, GL codes, cost-center references — no real NPI) through the covered channels.	Legitimate finance traffic is **not** matched — no spurious tips/blocks on internal reference/GL numbers.
B3	Post-tuning re-measure	After each tuning change (confidence↑, instance count↑, keywords, EDM, exceptions), re-simulate and re-measure.	FP rate trends **down** while true positives (Test A) still fire.
B4	Override sanity	In the finance ring, review captured **allow-with-justification** overrides.	Overrides are legitimate business justifications (e.g. a sanctioned vendor payment), not routine bypass — if routine, re-tune or re-scope.

Gate B (pass): measured FP rate at/under threshold on the simulation sample with true positives intact.

Test C — Incident / alert handling (the control is operable)

#	Test	Steps	Pass condition
C1	Alert raised	Trigger a policy match (Test A1/A4).	A DLP **alert** appears in **Purview** → **Data loss prevention** → **Alerts** with the correct policy, severity, and evidence.
C2	Triage workflow	The `DLP Alerts – Financial – Operations` owner/queue picks up the alert, sets status, and dispositions it.	Alert moves through the defined states to a resolved disposition by the named owner.

#	Test	Steps	Pass condition
C3	Evidence-access control	Confirm only authorized triagers can view the NPI in the match evidence (Req 2.7).	NPI match evidence is visible only to the authorized role — not to all reviewers.
C4	Activity Explorer trail	Locate the same event in **Data classification** → **Activity explorer**.	Full evidence trail present (user, location, SIT, action) for investigation.
C5	SIEM forwarding (if configured)	Confirm the DLP event reaches the SIEM/Sentinel destination (Req 2.7).	Event present in the downstream system with usable fields.

Gate C (pass): matches raise alerts, alerts are triaged to disposition by the owner with controlled evidence access, and the evidence trail (and SIEM forward, if used) is present.

Simulation-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Users/devices **outside** `DLP Pilot Ring – Finance Stage1` experience no blocking during pilot.
S2	Instant rollback	Setting any enforced policy back to **simulation mode** immediately removes enforcement with no data change (verify a previously-blocked action now only simulates).
S3	Scripts are safe-by-default	`DLPFIN-Config.ps1` / `DLPFIN-Scope.ps1` run **without** `-Commit` make no change (`-WhatIf` output only); Discovery/Report/health-check scripts are read-only.

Evidence to capture (for the GLBA/SOX control record)

- Baseline posture CSV (Phase 0) and the financial-SIT coverage map.
- Simulation match export + TP/FP classification and the computed **false-positive rate** before/after tuning (Gate B).
- Screenshots/log of Test A enforcement actions and the raised alerts (Gate A/C).
- The dispositioned incident from Test C2, the evidence-access check (C3), and, if used, the SIEM forward

(C5).

- Confirmation that outside-ring users were unaffected (S1) and that simulation rollback works (S2).

> ***Determination boundary.*** *These tests prove the* ***control works****. Whether a given category's enforced action and FP threshold are *acceptable* for GLBA/SOX, and whether the data is in regulatory scope, is a compliance/privacy/legal sign-off, captured alongside the evidence above.*

6. Troubleshooting — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

Symptom-first fixes for the failures you actually hit implementing financial/NPI DLP across email, cloud, Teams, and endpoint. Most problems are one of: a policy not matching, the endpoint location unavailable, too many false positives on financial numbers, or matches that raise no alert.

Policy / detection

A financial DLP policy matches nothing even though the content clearly contains NPI.

- Confirm the policy is actually **enabled and in a mode that evaluates** — a *disabled* policy does

nothing; a **simulation** policy evaluates and logs but does not block. Check with `DLPFIN-Discovery.ps1` (Mode column) or `DLPFIN-Validate.ps1`.

- Check the **instance count and confidence** on the rule — if it requires ≥10 matches at High confidence

and your test file has 1 fake account number, it correctly won't fire. Lower the threshold for testing, or add more sample instances.

- **Policy propagation takes time** — newly created/changed DLP policies can take **up to ~1 hour (and

longer for some locations)** to take effect. Wait before concluding it's broken.

- Confirm the **location scope** includes where you're testing (e.g. the specific finance site/user), and

that the test identity isn't in an **exclusion** (e.g. the payments-processor mailbox you excepted).

A custom `Account Number` / `GL Account Code` SIT never matches.

- Test the SIT's **regex + keywords** in the SIT wizard's **Test** step with known-matching text. A too-

strict regex, wrong **character proximity**, or a required keyword (e.g. *account*, *acct*) that isn't present will suppress all matches. Loosen and re-test incrementally.

The GLBA / U.S. Financial Data template isn't where the docs say, or has different SITs.

- **Template names and membership evolve.** Verify the exact template name and its bundled SITs in your

tenant (**Data loss prevention** → **Create policy**); the pack flags this rather than asserting a fixed name. If the template doesn't fit, build a custom policy with the financial SITs you confirmed in Discovery.

Matches appear in simulation but nothing is blocked.

• That is **correct** — simulation logs what *would* happen without enforcing. To block, move the policy to

enforce for the finance ring (Implementation Phase 4) after compliance signs off the enforced action.

Endpoint DLP (finance/treasury laptops)

The Devices/Endpoint location isn't available when creating a policy.

• **Licensing:** Endpoint DLP requires the appropriate plan (E5 / E5 Compliance) — run `DLPFIN-Scope.ps1`

(health section) for the licensing signal and **verify in the admin center**.

• **Onboarding:** the Devices location depends on **onboarded devices** — confirm in **Purview portal → Settings → Device onboarding**. No onboarded finance devices → the location does nothing even if selectable.

Endpoint policy is enforced but device activities (USB/print/upload) aren't caught.

• Confirm the specific **finance device is onboarded and reporting** (portal device list), meets the

minimum OS build, and — for some activities — that the required agent/AV prerequisites per Microsoft docs are met.

• Confirm the **activity is in scope** of the rule (e.g. "copy to USB" is enabled) and that the app/browser or network path isn't on an **allowed/exception** list (a sanctioned finance tool may be allow-listed).

• Allow for **reporting latency** — endpoint events can take time to surface in Activity Explorer.

False positives (the adoption killer for finance)

Finance users get policy tips on legitimate, non-sensitive content (GL codes, invoice IDs, reference numbers).

• Export matches with `DLPFIN-Report.ps1 -CsvPath ...`, classify TP/FP, and identify the driver — often a

built-in *Credit Card* / *ABA Routing* SIT firing on internal numbers, or an over-broad custom `Account Number` SIT.

• **Raise confidence** (medium→high) and/or **instance count** so single/low-confidence hits don't fire.

• Add **supporting keywords/proximity** to custom SITs so financial context is required, not just a numeric

pattern.

• For a built-in SIT that over-matches your internal identifiers, move that category to **Exact Data Match** (`Customer NPI – EDM – Financial`) so only your real account data matches.

• Add a targeted **exception** where justified (e.g. the reconciliation site, the payments mailbox) — narrowly, with a documented reason.

• Re-simulate after each change and re-measure — don't stack multiple changes blind.

Alerts / incident handling

Financial DLP matches occur but no alert appears / no one is notified.

- Confirm **alerts are configured** on the rule (alert on match, threshold) and check **Purview → Data loss

prevention → Alerts**. Some low-severity matches aggregate rather than alert per event.

- Confirm **audit logging is enabled** in the tenant — the report script and Activity Explorer rely on it.
- Confirm the **triage owner/queue** (`DLP Alerts – Financial – Operations`) exists and, if forwarding to

SIEM/Sentinel, that the connector is healthy (Req 2.7).

Triagers can't see (or can see too much of) the NPI in the match evidence.

- Match evidence contains protected data. Confirm the **evidence-access control** (Req 2.7) grants view of

NPI only to the authorized role — adjust role-group membership so triage works without over-exposing NPI.

The report script returns no matches.

- **Audit log latency:** DLP events can take time to appear; widen `-Days` and re-run (default 30 spans a

reporting cycle).

- Freshly created policies need **dwell time** — there may simply be no matches yet.
- Confirm **audit logging is on** and your account has the **View-Only DLP / audit** role.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

- Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth /

MFA-capable** admin.

- Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data

Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

A script made an unexpected change.

- The delivered scripts are **read-only or** `-WhatIf` **by default**; writes require `-Commit`. `DLPFIN-Config.ps1`

never leaves a policy in **enforce** and `DLPFIN-Scope.ps1` never flips enforcement mode, so the safe recovery is always to set the policy back to **simulation** in the portal (one setting, no data change).

Fast triage table

Symptom	First check
Policy matches nothing	Mode (disabled/sim), instance count/confidence, propagation time, scope/exclusion
Custom account/GL SIT never fires	Test regex+keywords+proximity in the SIT wizard
GLBA template missing/different	Template names evolve — verify in tenant; build custom from confirmed SITs
Nothing blocked	Still in **simulation** — that's expected; enforce the finance ring to block
Devices location missing	Licensing (E5/E5 Compliance) + device **onboarding**
Endpoint activity not caught	Device onboarded/reporting, activity in scope, allowed-app/network exceptions
Too many false positives	Raise confidence/instance count, add keywords/EDM, exceptions, re-simulate
No alert on match	Alert config on rule, audit logging on, triage owner, SIEM connector
Evidence over/under exposed	Evidence-access role (Req 2.7)
Report returns nothing	Audit latency/dwell time, audit logging on, role
Cmdlet/connect fails	Module updated, modern auth, correct DLP role

7. Best Practices — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

Field-tested practices for running GLBA/SOX-aligned DLP for financial and NPI data across endpoint, cloud, and email so the control stays trusted, effective, low-noise, and defensible. These complement the Implementation and Testing guides.

Simulate before you enforce — always

• **Never** switch a new or materially changed financial DLP policy straight to enforce. Run it in

simulation first, long enough to capture representative finance traffic — **span at least one month-end/reporting cycle** (Req 2.6) — and read the results before enabling.

• Use **simulation with policy tips** on the finance pilot ring when you want end-user feedback before hard

block.

• Treat **simulation mode as your permanent safety switch**: any enforced policy can be returned to

simulation in one setting, instantly removing enforcement with no data change — this is your rollback, and it means a DLP change can never take down month-end close.

Tune for a low false-positive rate (adoption depends on it)

• Start at **higher confidence** and a **realistic instance count** — a single card/account number is noise; ten in one file is a leak. Bulk-exfiltration thresholds cut false positives dramatically.

• **Financial numeric patterns over-fire.** Built-in *Credit Card Number*, *ABA Routing Number*, and *U.S. Bank Account Number* SITs, and any broad custom `Account Number/GL Account Code` SIT, will match internal reference numbers, invoice IDs, and GL codes unless you require **supporting keywords and proximity** for context.

• Use **Exact Data Match** for customer NPI where pattern SITs over-fire — it matches your *actual* account data and drives false positives toward zero, at the cost of an upload + refresh cadence.

• Every false positive that reaches a finance user erodes trust in **every** policy tip. Budget for a tuning cycle, not a one-time build.

Right-size the user experience for finance

• Show **clear, actionable policy tips** in business language — tell the user *why* and *what to do*, not a compliance error code. Reuse one standard notice (`DLP Notice – GLBA NPI – AllPolicies`).

• Prefer **allow-with-justification / override** over hard block for categories with legitimate business exceptions (vendor payments, sanctioned external reporting), then **review the overrides** — routine overriding means the policy is mis-scoped.

• Reserve **hard block / encrypt** for the categories where compliance/legal require it (e.g. bulk customer NPI to external recipients); escalate to block one category at a time, re-validating each.

Endpoint DLP specifics (finance/treasury laptops)

• **Onboarding is the gate.** A Devices policy is inert until the finance device is onboarded (shared with Defender for Endpoint) and reporting — verify onboarding before blaming the policy.

• Roll endpoint controls out **audit-first**: audit USB/print/cloud-upload activities before restricting, so you see real finance workflows and avoid blocking legitimate ones.

• Mind **unallowed vs allowed apps/browsers and network exceptions** — allow sanctioned finance tools and network paths so they aren't caught alongside exfiltration paths.

Classification hygiene

• **Reuse built-in financial SITs and the GLBA / U.S. Financial Data templates** wherever they fit; build

custom/EDM/fingerprint/trainable only for genuine gaps (internal account numbers, GL codes, statement templates). Fewer, well-tuned detectors beat a sprawl of overlapping ones.

- **Version and document** each custom SIT/EDM schema/fingerprint (pattern, confidence, keywords, owner) so

tuning changes are traceable — traceability supports SOX change-control expectations.

- **Refresh EDM data and re-fingerprint statement templates** on a schedule — stale sources silently

degrade matching.

GLBA/SOX operations & governance

- Give financial DLP **alerts an owner and an SLA** (Req 2.7), and **control who may view NPI in the match

evidence** — the evidence itself contains protected data. Forward to SIEM/Sentinel where central SecOps needs visibility.

- **Separate policy authors from alert triagers** where possible — segregation of duties matters for SOX.

- Review **Activity Explorer** and the false-positive rate on a **recurring cadence**; re-tune as data and

behavior drift.

- Keep a **change log** of every simulate→enforce transition and every action escalation, with the

compliance sign-off attached — this is your GLBA safeguards / SOX control evidence.

Stay inside the boundary

- DLP is **one control**, not GLBA/SOX compliance on its own — it inspects content it can classify; combine

with sensitivity labels, encryption, access controls, and insider-risk where the risk warrants.

- **Verify licensing/tenant** before relying on any endpoint, EDM, fingerprinting, trainable-classifier, or

named-template capability — plans, portal paths, and template names evolve; don't assume a feature is present.

- **Which data is NPI under GLBA, which records are SOX-scoped, the enforced action per category, retention

obligations, and acceptable false-positive thresholds are compliance/records/privacy/legal determinations** — you provide the technical control and the evidence; they own the decision.

8. Deliverables Summary — Financial (GLBA/SOX) DLP Pack (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The financial-DLP model — financial/NPI SITs, EDM, statement fingerprinting, the five locations (email, SharePoint, OneDrive, Teams, endpoint), the GLBA/SOX framing, policy tips/overrides, and the simulate→enforce journey; naming convention.
Requirements Guide	Solution-specific prerequisites (DLP/Endpoint + advanced-classifier licensing, DLP roles with author/triage separation, finance device onboarding, financial classification intent, EDM/fingerprint source data, finance pilot ring, alert triage owner + evidence access) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/baseline → design financial SITs/EDM/fingerprints → build 4 policies **in simulation** → tune false positives → enforce to a finance ring → expand; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the three headline outcomes — financial/NPI leaks blocked (A), low false-positive rate (B), incidents handled with controlled evidence access (C) — plus simulation-first and rollback checks, all with fake test data.
Troubleshooting Guide	The common failure modes (policy not matching, endpoint location missing, floods of false positives on GL/reference numbers, no alerts) and how to resolve them.
Best Practices	Simulate-first discipline, financial false-positive tuning, user-experience design for finance, endpoint specifics, classification hygiene, and GLBA/SOX operations/governance.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`. No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Default safety
1	**DLPFIN-Discovery.ps1**	DLP posture + financial-SIT coverage assessment: existing policies and their mode, built-in financial vs custom SIT coverage, EDM schemas, licensing/endpoint readiness signals.	Read-only
2	**DLPFIN-Config.ps1**	DLP policy configuration helper: creates/updates a financial/NPI policy **in simulation mode** and reports the intended change.	`-WhatIf` (writes need `-Commit`; never leaves a policy in enforce)
3	**DLPFIN-Validate.ps1**	Validation runner: checks each expected financial policy exists, is in the intended mode (simulation vs enforce), covers the right locations/SITs, and reports pass/fail against the deployment gates.	Read-only
4	**DLPFIN-Report.ps1**	DLP match / false-positive tuning report: exports simulation/enforcement matches for TP-vs-FP classification and rate calculation.	Read-only
5	**DLPFIN-Scope.ps1**	Scope/health helper: reports a policy's scope + endpoint/licensing health signals and (with `-Commit`) narrows a policy to the finance pilot ring.	`-WhatIf` (writes need `-Commit`)

Definition of done

- Financial/NPI sensitive information types, EDM schemas, statement fingerprints, and classifiers mapped

for every in-scope category (built-in + GLBA/Financial-Data templates reused; custom/EDM/fingerprint/trainable only for gaps).

• Email, cloud (SPO/OneDrive/Teams), endpoint NPI, and SOX financial-records DLP policies built and **proven in simulation**.

• False-positive rate measured and tuned to at/under the agreed threshold across a reporting cycle (Gate B).

• Enforcement live for the finance pilot ring with policy tips + override, then expanded per compliance's action determination (Gate A).

• Financial DLP alerts raised, triaged to disposition with controlled evidence access, and evidence trailed in Activity Explorer (Gate C).

• Simulation-rollback and safe-by-default scripts verified; change log and compliance sign-offs captured for the GLBA safeguards / SOX control record.

> ***Boundary:*** *the solution delivers the technical control and the evidence.* ***Which data is NPI under GLBA, which records are SOX-scoped, which classifiers legally apply, the enforced action per category, retention obligations, and the acceptable false-positive threshold*** *are compliance/records/privacy/legal determinations, captured alongside the evidence.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DLPFIN-Config.ps1

Purpose: Creates a new DLP compliance policy (and a matching content rule for one or more FINANCIAL sensitive information types — e.g. Credit Card Number, ABA Routing Number, U.S. Bank Account Number) in SIMULATION mode, or updates an existing policy's rule, across the chosen locations (Exchange / SharePoint / OneDrive / Teams / Endpoint). Safe by default: with -WhatIf it only reports the intended change; it applies nothing unless -Commit is passed, and it NEVER creates or leaves a policy in enforce (Enable) mode — simulation only. Enforcement is a deliberate, separate portal/change-control step done after compliance signs off the enforced action. HOW TO RUN Preview an Exchange NPI simulation policy for built-in financial SITs: powershell -File .\DLPFIN-Config.ps1 -PolicyName 'DLP - Email NPI - Simulation' `-Locations Exchange -SensitiveTypes 'Credit Card Number','ABA Routing Number','U.S. Bank Account Number'` -MinCount 10 -Confidence High -WhatIf Actually create it (still simulation mode): powershell -File .\DLPFIN-Config.ps1 -PolicyName 'DLP - Email NPI - Simulation' ` -Locations Exchange -SensitiveTypes 'Credit Card Number','ABA Routing Number' -MinCount 10 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with DLPFIN-Discovery.ps1 / DLPFIN-Validate.ps1. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), Default to the core built-in financial/NPI SITs; override for custom SITs (e.g. 'Account Number - Custom SIT - Financial'). [string[]]$SensitiveTypes = @('Credit Card Number','ABA Routing Number','U.S. Bank Account Number'), [int]$MinCount = 10, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

How to run: Preview an Exchange NPI simulation policy for built-in financial SITs: powershell -File .\DLPFIN-Config.ps1 -PolicyName 'DLP - Email NPI - Simulation' `-Locations Exchange -SensitiveTypes 'Credit Card Number','ABA Routing Number','U.S. Bank Account Number'` -MinCount 10 -Confidence High -WhatIf Actually create it (still simulation mode): powershell -File .\DLPFIN-Config.ps1 -PolicyName 'DLP - Email NPI - Simulation' ` -Locations Exchange -SensitiveTypes 'Credit Card Number','ABA Routing Number' -MinCount 10 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with DLPFIN-Discovery.ps1 / DLPFIN-Validate.ps1. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]]$Locations = @('Exchange'), Default to the core built-in financial/NPI SITs; override for custom SITs (e.g. 'Account Number - Custom

SIT - Financial'). [string[]]$SensitiveTypes = @('Credit Card Number','ABA Routing Number','U.S. Bank Account Number'), [int]$MinCount = 10, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

DLPFIN-Discovery.ps1

Purpose: Builds the financial-DLP baseline: every existing DLP compliance policy with its MODE (enforce vs simulation vs disabled) and the locations it covers, plus coverage of the built-in FINANCIAL sensitive information types (Credit Card, ABA Routing, U.S. Bank Account, IBAN, SWIFT, SSN, ITIN) versus custom SITs, and any EDM schemas in the tenant. Read-only — makes no changes. Use it to see what already exists before you build simulation policies. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPFIN-Discovery.ps1 -CsvPath .\DLPFIN-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations) and a financial-SIT coverage summary (which built-in financial SITs are present, custom SIT count, EDM count), plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Read-only against Security & Compliance PowerShell. No credentials in code. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPFIN-Discovery.ps1 -CsvPath .\DLPFIN-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of DLP policies (Name, Mode, Locations) and a financial-SIT coverage summary (which built-in financial SITs are present, custom SIT count, EDM count), plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Read-only against Security & Compliance PowerShell. No credentials in code. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

DLPFIN-Report.ps1

Purpose: Exports DLP rule matches (Exchange, SharePoint/OneDrive, Teams, and Endpoint) over a time window so you can classify true-positive vs false-positive on FINANCIAL/NPI content and compute the false-positive rate that gates simulation-to-enforcement. Works for policies in simulation AND enforcement — simulation matches are logged the same way. Read-only — queries Search-UnifiedAuditLog only. Run over a window that spans a month-end/reporting cycle so finance traffic is representative. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPFIN-Report.ps1 -Days 30 -CsvPath .\DLPFIN-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true positives still present. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Read-only reporting from the unified audit log. Match evidence may contain NPI — handle per Req 2.7. > [CmdletBinding()] param([int]$Days = 30, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPFIN-Report.ps1 -Days 30 -CsvPath .\DLPFIN-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by workload and by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true positives still present. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Read-only reporting from the unified audit log. Match evidence may contain NPI — handle per Req 2.7. > [CmdletBinding()] param([int]$Days = 30, [string]$CsvPath, [string]$UserPrincipalName)

DLPFIN-Scope.ps1

Purpose: Two read-only health signals plus one gated write. (1) HEALTH: reports whether any DLP policy uses the Endpoint (Devices) location and a Graph-based licensing signal for advanced-compliance service plans, so you know Endpoint DLP can actually function before scoping finance endpoints. (2) SCOPE: reports the named policy's current locations, mode, and member-of scope, and — only with -Commit — narrows an Exchange/OneDrive policy to the FINANCE PILOT RING by setting the location member-of scope (e.g. ExchangeSenderMemberOf / OneDriveSharedByMemberOf), so enforcement can be limited to Finance/Treasury before tenant-wide expansion. Safe by default: -WhatIf reports only; writes require -Commit. This helper adjusts SCOPE only — it does NOT flip a policy to enforce (that is a deliberate portal/change-control action). HOW TO RUN Health + report current scope for a policy: powershell -File .\DLPFIN-Scope.ps1 -PolicyName 'DLP - Email NPI - Simulation' -WhatIf Restrict the Exchange policy to the finance pilot-ring group (still simulation mode): powershell -File .\DLPFIN-Scope.ps1 -PolicyName 'DLP - Email NPI - Simulation' ` -PilotRingGroup 'DLPFinancePilot@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession); Graph (Organization.Read.All) for the licensing signal. EXPECTED RESULTS Health lines (endpoint location in use? advanced-compliance plan present?) plus, for scope: -WhatIf prints the current locations/mode and the Set-DlpCompliancePolicy call it WOULD run; -Commit applies the member-of scope and re-prints it. PASS: the policy's *MemberOf scope now equals the finance ring, and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [switch]$SkipHealth, [string]$UserPrincipalName, [switch]$Commit)

How to run: Health + report current scope for a policy: powershell -File .\DLPFIN-Scope.ps1 -PolicyName 'DLP - Email NPI - Simulation' -WhatIf Restrict the Exchange policy to the finance pilot-ring group (still simulation mode): powershell -File .\DLPFIN-Scope.ps1 -PolicyName 'DLP - Email NPI - Simulation' ` -PilotRingGroup 'DLPFinancePilot@contoso.com' -Location Exchange -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession); Graph (Organization.Read.All) for the licensing signal. EXPECTED RESULTS Health lines (endpoint location in use? advanced-compliance plan present?) plus, for scope: -WhatIf prints the current locations/mode and the Set-DlpCompliancePolicy call it WOULD run; -Commit applies the member-of scope and re-prints it. PASS: the policy's *MemberOf scope now equals the finance ring, and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Scope changes gated behind -Commit; never changes enforcement mode. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [ValidateSet('Exchange','SharePoint','OneDrive','Teams')][string]$Location = 'Exchange', [switch]$SkipHealth, [string]$UserPrincipalName, [switch]$Commit)

DLPFIN-Validate.ps1

Purpose: Validates the financial-DLP deployment against the pack's expected artifacts: for each expected policy (Email NPI, Cloud NPI, Endpoint NPI, SOX Financial Records) it checks the policy EXISTS, reports its MODE (flagging any policy in enforce that you did not intend), confirms it covers the expected locations, and confirms a content rule with sensitive-information-type conditions is attached. Prints a PASS/FAIL line per check for the deployment gates. Read-only — makes no changes. Use it after DLPFIN-Config.ps1 and again after enforcement to prove state. HOW TO RUN Validate the default expected policy set (simulation stage): powershell -ExecutionPolicy Bypass -File .\DLPFIN-Validate.ps1 Validate a specific set and expect them in simulation: powershell -File .\DLPFIN-Validate.ps1 -PolicyNames 'DLP - Email NPI - Simulation','DLP - SOX Financial Records - Simulation' -ExpectMode Simulation Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A per-policy PASS/FAIL table (Exists / ModeOK / HasRule / Locations) and an overall result. PASS gate: every expected policy exists, is in the expected mode, and has a rule with SIT conditions. FAIL: a missing policy, an unexpected enforce mode, or a policy with no rule. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Read-only validation. No changes made. No credentials in code. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - Email NPI - Simulation', 'DLP - SPO+OneDrive+Teams NPI - Simulation', 'DLP - Endpoint NPI - Simulation', 'DLP - SOX Financial Records - Simulation'), [ValidateSet('Simulation','Enforce','Any')][string]$ExpectMode = 'Simulation', [string]$UserPrincipalName)

How to run: Validate the default expected policy set (simulation stage): powershell -ExecutionPolicy Bypass -File .\DLPFIN-Validate.ps1 Validate a specific set and expect them in simulation: powershell -File .\DLPFIN-Validate.ps1 -PolicyNames 'DLP - Email NPI - Simulation','DLP - SOX Financial Records - Simulation' -ExpectMode Simulation Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A per-policy PASS/FAIL table (Exists / ModeOK / HasRule / Locations) and an overall result. PASS gate: every expected policy exists, is in the expected mode, and has a rule with SIT conditions. FAIL: a missing policy, an unexpected enforce mode, or a policy with no rule. .NOTES Purview — Financial (GLBA/SOX) DLP Pack. Read-only validation. No changes made. No credentials in code. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - Email NPI - Simulation', 'DLP - SPO+OneDrive+Teams NPI - Simulation', 'DLP - Endpoint NPI - Simulation', 'DLP - SOX Financial Records - Simulation'), [ValidateSet('Simulation','Enforce','Any')][string]$ExpectMode = 'Simulation', [string]$UserPrincipalName)